



# API 인가 취약점 진단 및 개인정보 노출 영향도 산정

AP-EYE

곽민경, 심재훈, 양유상, 임성빈

2026-2 정보보안S/W융합전공 Project Kick-Off

# 01

## 팀원 소개 및 배경

- 팀원 소개
- 시장 동향 및 실태
- 프로젝트 목표

# 02

## 프로젝트 소개

- 프로젝트 범위
- 프로젝트 시도 항목
- 프로젝트 선행 항목

# 03

## 프로젝트 일정

- WBS

# 04

## 마무리

- 목표 산출물
- Q&A

# 01

## 팀원 소개

Team Members



**심재훈**  
PM



**임성빈**  
PA



**양유상**  
PA



**곽민경**  
PA

# 01

## 시장 동향 및 실태

Trends & Landscape

<https://www.cyberinfos.in/api-data-breaches-2026-leaked-millions> (2026.08.15, CyberInfos)

DATA BREACHES

### API Data Breaches 2026: How Exposed APIs Leaked Millions of Records

#### What's Actually Happening to APIs in 2026

Industry surveys now put the share of organizations reporting at least one **API-related security issue** in the past year at close to universal. The average API incident is exposing well over a million records noticeably higher than breaches that start elsewhere in the stack.

지난 1년간 **API 관련 보안 사고**를 한 건이라도 겪은 조직이 대다수이며,  
**평균 API 유출 규모는 100만 건**을 훌쩍 넘고있다는 업계 설문 결과가 있었습니다.

# 01

## 시장 동향 및 실태

Trends & Landscape

<https://www.cyberinfos.in/api-data-breaches-2026-leaked-millions> (2026, CyberInfos)

DATA BREACHES

### API Data Breaches 2026: How Exposed APIs Leaked Millions of Records

#### Instagram API scraping exposure – January 2026.

One of the earliest entries in the API data breaches 2026 has recorded. A dataset of roughly 17.5 million user records surfaced on a **dark web** marketplace, including names, email addresses, phone numbers, and partial location data. The platform maintained the data was technically “public,” but the scale and structure of the leak made it functionally identical to a breach for the people affected. It’s a reminder that API exposure doesn’t require a broken lock just an interface that hands out more than it should to anyone who asks in bulk.

Instagram API 스크래핑 유출로 약 1750만 건의 사용자 기록이 다크웹에 유통되었습니다.

# 01

## 시장 동향 및 실태

Trends & Landscape

<https://www.munhwa.com/article/11601272> (2026.07.08, 문화일보)



개인정보위는 사업자가 API 설계 단계부터 개인정보 최소화 원칙을 적용해야 한다고 권고했다. 이용자 화면에 보이지 않거나 서비스 제공 목적에 필요하지 않은 정보는 API 응답 데이터에서도 제외하고, 대규모 정보 조회나 반복 호출은 제한해야 한다는 것이다.

2026년 7월에도 개인정보위에서는 **API 권한관리 미흡을 공식 경고**했습니다.

# 01

## 시장 동향 및 실태

Trends & Landscape

주문조회 API 뚫린 '29CM'... 이름·배송정보 등 15만9852건 ...

2026. 8. 30. — 29CM가 자사 홈페이지 공지사항을 통해 밝힌 내용에 따르면, 지난 8월 27일 주문정보를 조회하

위버스, 결제 API 뚫려 42만건 정보 유출... “민감 정보는 무사”

2026. 9. 7. — 위버스, 결제 API 뚫려 42만건 정보 유출... “민감 정보는 무사”. 외부 노출 API 노린 우회 공격으로

성형 사진부터 피부타입까지 털렸다... 강남언니·화해 고객 ...

2026. 9. 7. — 강남언니에서 유출 항목은 이름과 연락처 등 기본 정보 외에도 △상담 등록 사진 △예약 희망 시간

채용 플랫폼 레쥬메나인 개인정보 유출... 원인은 '서버 권한 ...

2026. 9. 14. — 로그인 및 권한 확인이 누락된 일부 서버 기능에 외부 접근이 발생해 회원 정보가 권한 없이 조회  
된 사실이 확인된 것이다. 7일엔 관련 파일에 접근할 수 ...

그럼에도 두 달 뒤인 현재에도 여러 기업에서 같은 원인으로 유출이 발생하고 있습니다.

# 01

## 시장 동향 및 실태

Trends & Landscape



Filter links

- [Add-ons](#)
- [Access Control Testing](#)
  - [Access Control Context Options](#)
  - [Access Control Status Tab](#)
- [Active Scan Rules](#)
- [Active Scan Rules - Alpha](#)
- [Active Scan Rules - Beta](#)
- [Advanced SQLInjection Add-on](#)
- [AJAX Spider](#)
  - [Ajax Spider Automation Framework Support](#)
  - [AJAX Spider Context](#)
  - [Options AJAX Spider screen](#)
  - [AJAX Spider dialog](#)
  - [AJAX Spider tab](#)
- [Alert Filters](#)
  - [Alert Filter Dialog](#)
  - [Alert Filter Automation Framework Support](#)
  - [Context Alert Filters](#)
  - [Options Global Alert Filters](#)
  - [Alert Filter LLM Support](#)
- [All In One Notes](#)
- [All In One Notes -](#)

DOCUMENTATION > THE ZAP BY CHECKMARX DESKTOP USER GUIDE > ADD-ONS > ACCESS CONTROL TESTING

## Access Control Testing

This add-on enables users to compare which parts of a web-application are available to some users, do access control testing and identify potential access control issues. It allows configuration of access rules and conducts a full attack aimed to help identify sections of a web application which are accessible by unauthorized clients.

There are two main concepts related to this add-on that should be explained: the **Access Rules** and the **testing procedure**.

### Access Rules [↗](#)

In order to identify potential access control issues, ZAP needs to know which parts of the web application are supposed to be accessed by which user. In ZAP, the name for these rules is: *Access Rules* and generally have the meaning: "*PageA should/shouldn't be accessed by UserX*".

The rules are configured for a Context and, for each User of that Context, each Site Node (web page) will be associated to one of the following values:

- **Allowed** - the resource **can** be accessed by the User to which the rule refers
- **Denied** - the resource **should not** be accessed by the User to which the rule refers
- **Unknown** - there is **no information** regarding whether the resource

기존 인가 테스트 도구는 누가 무엇에 접근할 수 있는지 사람이 권한표를 먼저 작성해야 동작합니다.

# 01

## 시장 동향 및 실태

Trends & Landscape

### 정의된 유형

—  
인도  
미국  
영국  
핀란드  
캐나다  
독일  
일본  
EU

```
1  {
2    "types": [
3      {"name": "PAN CARD", "regexPattern": "[A-Z]{5}[0-9]{4}[A-Z]{1}", "sensitive": false, "onKey": false, "active": false},
4      {"name": "US Medicare Health Insurance Claim Number", "regexPattern": "[0-9]{9}[A-Za-z]{1}[0-9a-zA-Z]?", "sensitive": true, "onKey": false, "active": true},
5      {"name": "Indian Unique Health Identification", "regexPattern": "[0-9]{14}", "sensitive": false, "onKey": false, "active": true},
6      {"name": "United Kingdom National Insurance Number", "regexPattern": "(?!BG)(?!GB)(?!NK)(?!KN)(?!NT)(?!TN)(?!ZZ)(?! )", "sensitive": true, "onKey": false, "active": true},
7      {"name": "Finnish Personal Identity Number", "regexPattern": "([0-2][0-9]|[3-3][0-1])([0-0][1-9]|[1-1][0-2])[0-9]{4}", "sensitive": true, "onKey": false, "active": true},
8      {"name": "Canadian Social Insurance Number", "regexPattern": "[0-9]{9}", "sensitive": false, "onKey": false, "active": true},
9      {"name": "German Insurance Identity Number", "regexPattern": "[0-9]{2}([0-2][0-9]|[3-3][0-1])([0-0][1-9]|[1-1][0-2])[0-9]{4}", "sensitive": true, "onKey": false, "active": true},
10     {"name": "Japanese Social Insurance Number", "regexPattern": "[0-9]{12}", "sensitive": false, "onKey": false, "active": true},
11     {"name": "IBAN EUROPE", "regexPattern": "[A-Z]{2}[ ]?[0-9]{2}[ ]?\\s*(\\d{4}\\s*){4,10}(\\d{1,2}\\s*)?", "sensitive": true, "onKey": false, "active": true},
12     {"name": "US ADDRESS", "regexPattern": "\\d{1,5}(\\s[\\w-.,,]*){1,6},\\s[A-Z]{2}\\s\\d{5}\\b", "sensitive": false, "onKey": false, "active": true},
13   ]
14 }
```

개인정보를 분류하는 도구도 있지만 한국 개인정보보호법 기준은 없습니다.

# 01

## 시장 동향 및 실태

Trends & Landscape

### 보안관리의 시작 U-PRIVACY SAFER V3.0

네트워크 상에서 발생하는 업무의 순간,  
문서와 이미지에 포함된 개인정보를 자동 추출하고  
스케줄링하여 관리 효율과 보안 수준을 동시에 높입니다.

문의하기

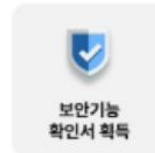
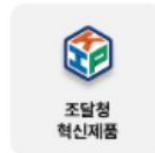
나라장터 바로가기



### 개인정보 유출, 네트워크에서 차단합니다.

HTTP/HTTPS 구간에서 개인정보를 실시간으로 탐지하고 차단합니다.

웹사이트 게시판, 첨부파일 업로드 등 다양한 경로를 감지해 사고 발생 전, 선제적으로 대응할 수 있습니다.



### U-PRIVACY SAFER V3.0

### 개인정보 필터링 솔루션

민감정보가 포함된 텍스트와 이미지 데이터를 자동으로 탐지하고,  
스케줄 기반 점검과 직관적인 결과 제공으로 효율적인 대응이 가능한 솔루션입니다.

국산 솔루션은 개인정보가 나가는 것을 막지만 요청자 본인의 정보인지는 판단하지 않습니다.

# 01

## 시장 동향 및 실태

Trends & Landscape

| 도구                         | 인가 테스트 | 민감정보 분류 | 사람이 넣어야 하는 것                            |
|----------------------------|--------|---------|-----------------------------------------|
| ZAP Access Control Testing | 있음     | 없음      | 사용자별로 페이지마다<br>Allowed, Denied, Unknown |
| Autorize (Burp)            | 있음     | 없음      | 저 권한 세션 헤더, 판정용 응답 매칭 필터                |
| Akto                       | 있음     | 있음      | 인증 컨텍스트                                 |
| Wallarm API Firewall       | 없음     | 없음      | OpenAPI 명세                              |
| open-appsec                | 없음     | 없음      | 해당 없음 (런타임 방어)                          |
| Schemathesis               | 없음     | 없음      | OpenAPI 또는 GraphQL 스키마                  |

# 01

## 프로젝트 목표

Project Objectives

**권한표 없이 트래픽만으로 인가 실패를 탐지하고  
개인정보 노출 영향도를 산정해 수정 우선순위까지 제시합니다.**

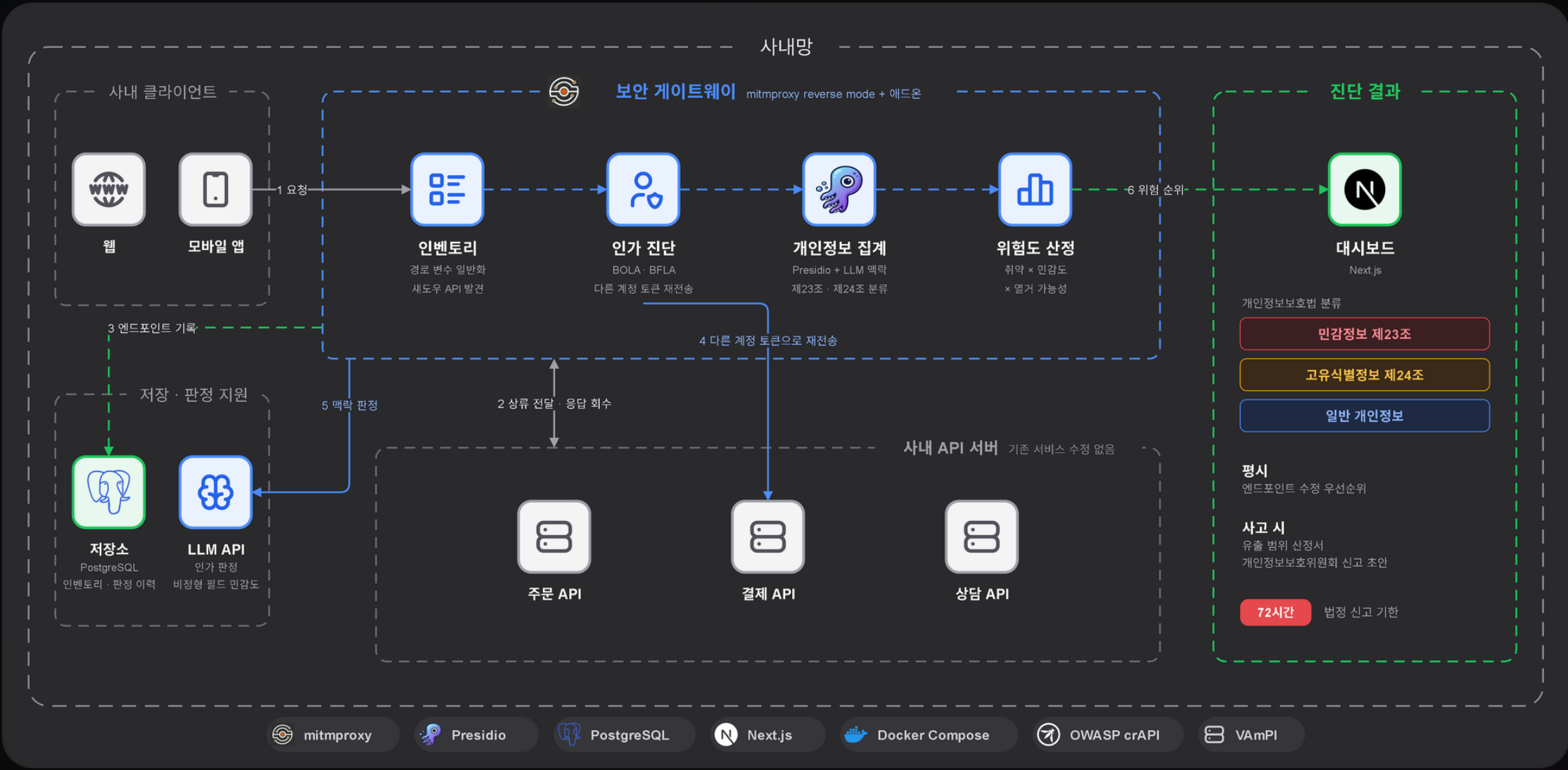
# 02

## 프로젝트 범위

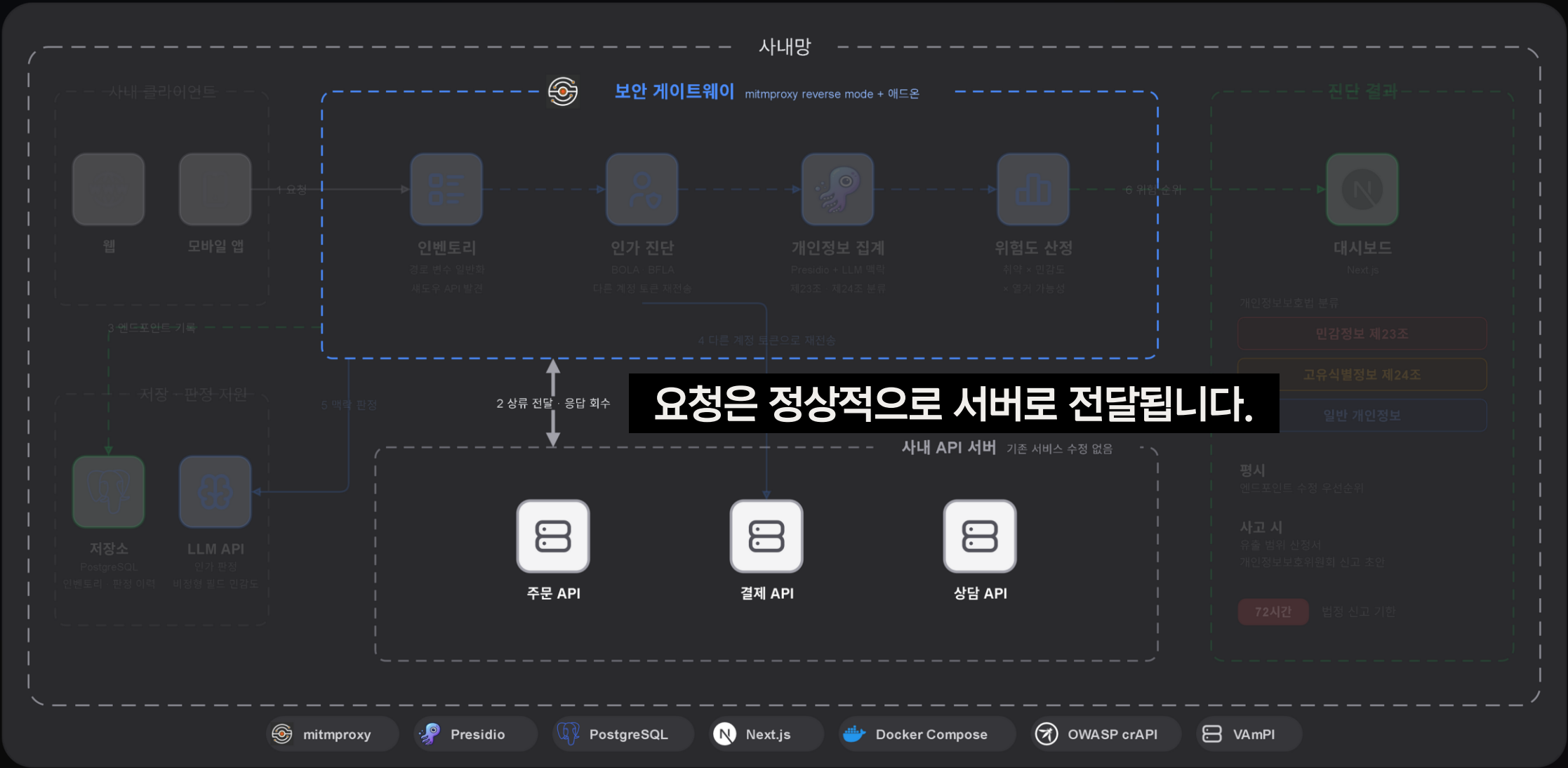
Project Scope

- 다루는 것
- 다루지 않는 것

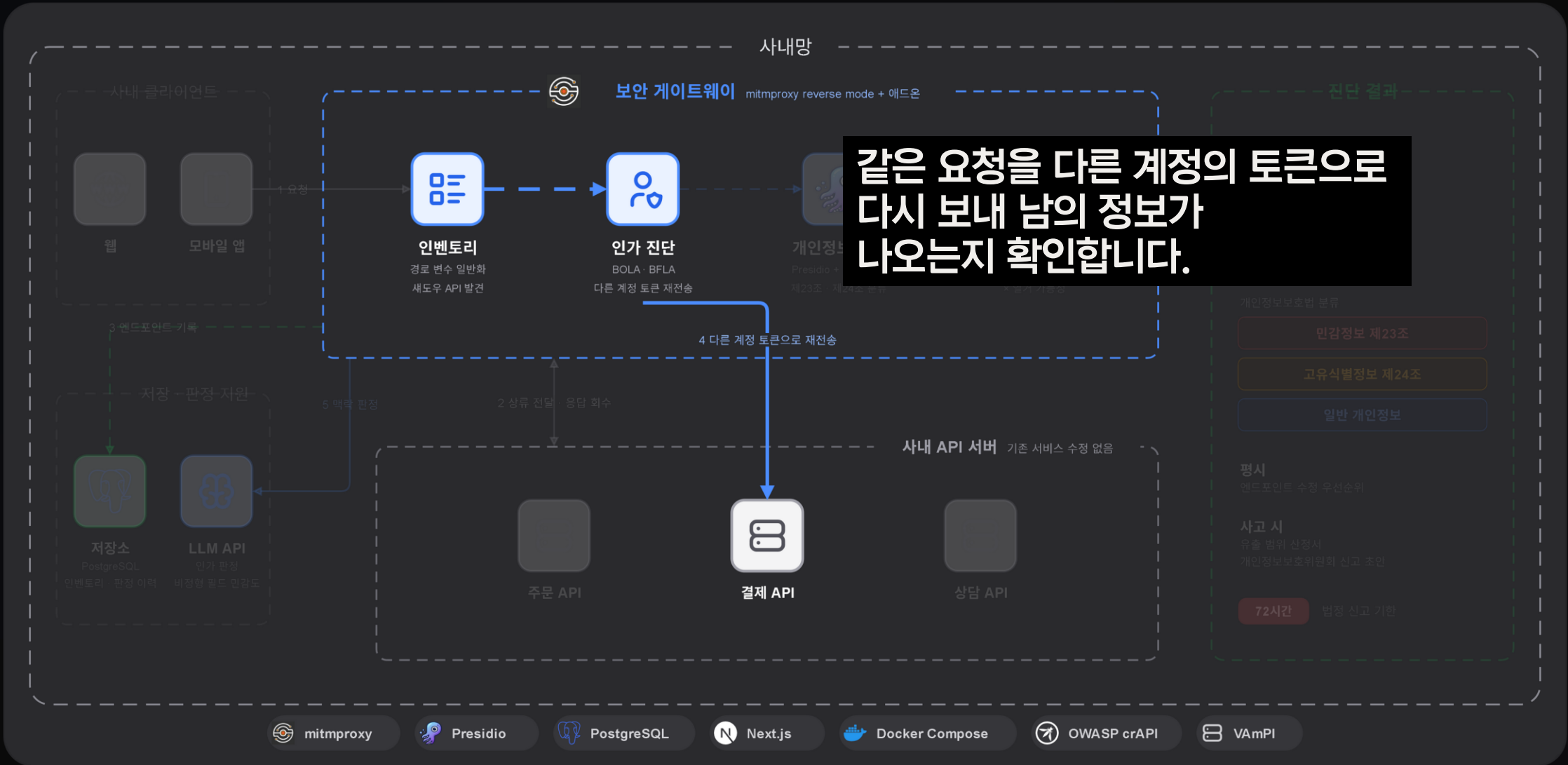


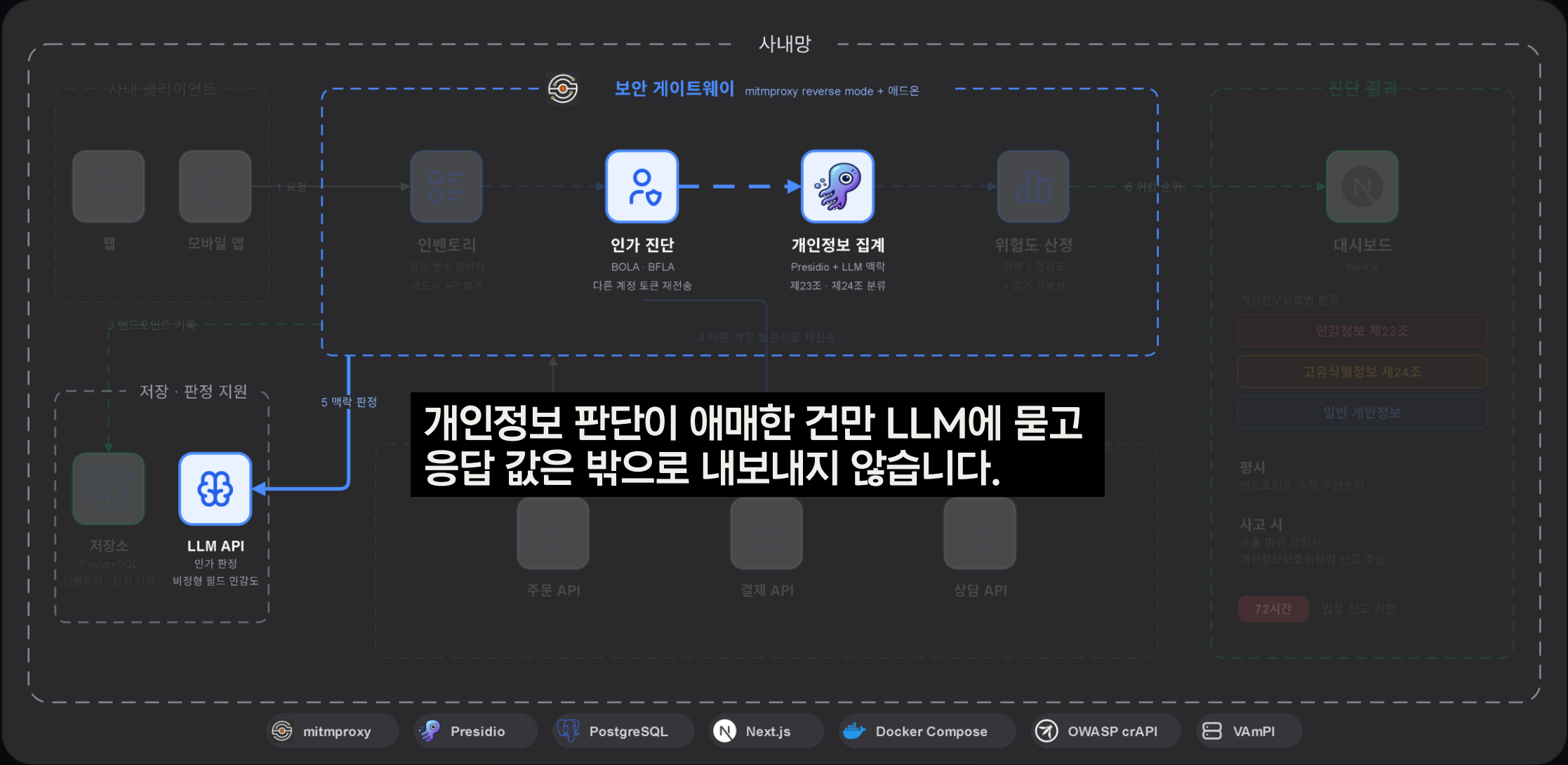














# 02

## 프로젝트 선행 연구

Proof of Concept

OWASP API1:2023 BOLA + API3:2023 BOPLA

문제가 존재하는지  
직접 확인했습니다.

```
// 1) 공격자 계정(B, pogba006)으로 로그인해 토큰 획득
> const token = "eyJhbGciOiJIUzI1NiJ9.eyJzdWIiOiJwb2diYTAwNkBlcGF ... 29J55G4Emgdg" //
pogba006@example.com

// 2) 남의 차량(A, adam007 소유)의 위치를 B의 토큰으로 요청
> await fetch("/identity/api/v2/vehicle/f89b5f21-7829-45cb-a650-299a61090378/location", {
  headers: { Authorization: "Bearer " + token }
})

200 OK 69 ms · 남의 차량인데 거절되지 않음

// 3) 응답 - 소유자 A(adam)의 이름·이메일·좌표가 그대로 반환
{
  "carId": "f89b5f21-7829-45cb-a650-299a61090378",
  "vehicleLocation": {
    "id": 1,
    "latitude": "32.778889",
    "longitude": "-91.919243"
  },
  "fullName": "Adam",
  "email": "adam007@example.com"
}
```

타인의 계정 토큰만으로 소유자의  
정보가 노출됐습니다.

# 02

## 프로젝트 선행 연구

Proof of Concept

JEV 방식 분류기 사전 실험

개인정보를 개인정보보호법으로 분류 되는지 확인했습니다.

CONFUSION MATRIX

어떤 분류끼리 혼동했나요?

방식 Semlf

행은 기대 분류, 열은 모델의 예측입니다. 각 셀은 예시 수입니다. 좁은 화면에서는 표를 가로로 움직일 수 있습니다.

| 기대 i / 예측 ←                 | 건강·의료 | 종교·신앙 | 연락처·주소 | 법정 식별번호 유형 | 사람 이름 | 회원·계정 식별자 | 그 밖의 정보 | 정보 부족·판단 보류 |
|-----------------------------|-------|-------|--------|------------|-------|-----------|---------|-------------|
| 건강·의료<br>HEALTH             | 10    | 0     | 0      | 0          | 0     | 0         | 1       | 1           |
| 종교·신앙<br>RELIGION           | 0     | 11    | 0      | 0          | 0     | 0         | 0       | 1           |
| 연락처·주소<br>CONTACT           | 0     | 0     | 11     | 1          | 0     | 0         | 0       | 0           |
| 법정 식별번호 유형<br>GOVERNMENT_ID | 0     | 0     | 0      | 12         | 0     | 0         | 0       | 0           |
| 사람 이름<br>PERSON_NAME        | 0     | 1     | 0      | 0          | 11    | 0         | 0       | 0           |
| 회원·계정 식별자<br>ACCOUNT_ID     | 0     | 0     | 0      | 1          | 0     | 11        | 0       | 0           |
| 그 밖의 정보<br>OTHER            | 1     | 0     | 0      | 0          | 0     | 1         | 6       | 4           |
| 정보 부족·판단 보류                 | 0     | 0     | 0      | 1          | 1     | 0         | 0       | 10          |

LIMITS

결과는 검토 후보 | 높은 점수의 오분류도 있어 자동 법률 판단 금지

# 03 프로젝트 일정

|                 | September |        |        |        | October |        |        |        | November |         |         |         | December |         |         |
|-----------------|-----------|--------|--------|--------|---------|--------|--------|--------|----------|---------|---------|---------|----------|---------|---------|
| Task / Duration | Week 1    | Week 2 | Week 3 | Week 4 | Week 5  | Week 6 | Week 7 | Week 8 | Week 9   | Week 10 | Week 11 | Week 12 | Week 13  | Week 14 | Week 15 |
| 프로젝트 계획 수립      |           |        |        |        |         |        |        |        |          |         |         |         |          |         |         |
| 킵오프             |           |        |        |        |         |        |        |        |          |         |         |         |          |         |         |
| 엔드포인트 복원        |           |        |        |        |         |        |        |        |          |         |         |         |          |         |         |
| 안거 취약점 탐지       |           |        |        |        |         |        |        |        |          |         |         |         |          |         |         |
| 영향도 선정          |           |        |        |        |         |        |        |        |          |         |         |         |          |         |         |
| 평가 자동화          |           |        |        |        |         |        |        |        |          |         |         |         |          |         |         |
| 중간 발표           |           |        |        |        |         |        |        |        |          |         |         |         |          |         |         |
| 파이프라인 통합        |           |        |        |        |         |        |        |        |          |         |         |         |          |         |         |
| 시나리오 구축 및 데모    |           |        |        |        |         |        |        |        |          |         |         |         |          |         |         |
| 비교 실험 및 성능 개선   |           |        |        |        |         |        |        |        |          |         |         |         |          |         |         |
| 리포트 제작          |           |        |        |        |         |        |        |        |          |         |         |         |          |         |         |
| 최종 발표           |           |        |        |        |         |        |        |        |          |         |         |         |          |         |         |

# 04

## 프로젝트 목표 산출물

Project Deliverables

### 1. API 개인정보 노출 진단 시스템



# 04

## 프로젝트 목표 산출물

### Project Deliverables

## 2. 논문 투고

### Automated BOLA/BFLA Detection and PIPA-Based Privacy Exposure Scoring

**Abstract**—In modern web and mobile applications, improper authorization control remains one of the most prevalent and critical security vulnerabilities. Broken Object Level Authorization (BOLA) and Broken Function Level Authorization (BFLA) on lead to severe privacy breaches. In this paper, we propose an automated detection approach for BOLA/BFLA model to quantify the real-world impact of unauthorized access, infer system-level logic, and scoring dynamic. We analyze the data privacy regulations and results on real-world alignment and privacy regulations. Experimental results effectively detect, enabling faster and provides meaningful risk prioritization, enabling more efficient and informed remediation efforts.

**Index Terms**— API security, BOLA, BFLA, privacy exposure, automated detection, PIPA

#### I. INTRODUCTION

The rapid growth of web and mobile services has led to increasing reliance on APIs for data exchange and functional access. While APIs enable innovation and scalability, they also introduce significant security risks, especially in authorization control. Broken Object Level Authorization (BOLA) [1] and Broken Function Level Authorization (BFLA) [2] are among the most common and impactful vulnerabilities, often resulting in unauthorized access to sensitive data or critical functionality. Despite their prevalence, many organizations still struggle to detect and prioritize these issues effectively.

In addition to the functional risk, the privacy impact of such vulnerabilities has become a major concern due to increasingly strict data protection regulations, including the Personal Information Protection Act (PIPA). Simply identifying a vulnerability is not sufficient; understanding the type and sensitivity of exposed data is essential for risk assessment and remediation prioritization.

In this paper, we present an automated detection framework for BOLA and BFLA, integrated with a PIPA-based privacy exposure scoring model. Our approach combines static and dynamic analysis to identify authorization flaws and evaluates their potential privacy impact based on the type, sensitivity, and context of exposed data.

#### II. METHODOLOGY

##### A. Overall Pipeline



Fig. 1. Overall pipeline of the proposed approach.

##### B. Privacy Exposure Scoring

We define a privacy exposure score based on data type, sensitivity level, and regulatory context. Each detected endpoint is analyzed for potentially exposed personal information, and a weighted scoring model is applied to quantify the overall risk.

#### III. EXPERIMENTAL RESULTS

##### A. Detection Performance

TABLE I. Detection performance comparison

| Method          | Precision | Recall | F1-score |
|-----------------|-----------|--------|----------|
| Baseline        | 0.78      | 0.71   | 0.74     |
| Proposed (Ours) | 0.92      | 0.88   | 0.90     |

##### B. Privacy Exposure Scoring Results

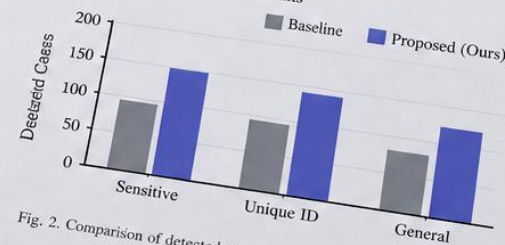


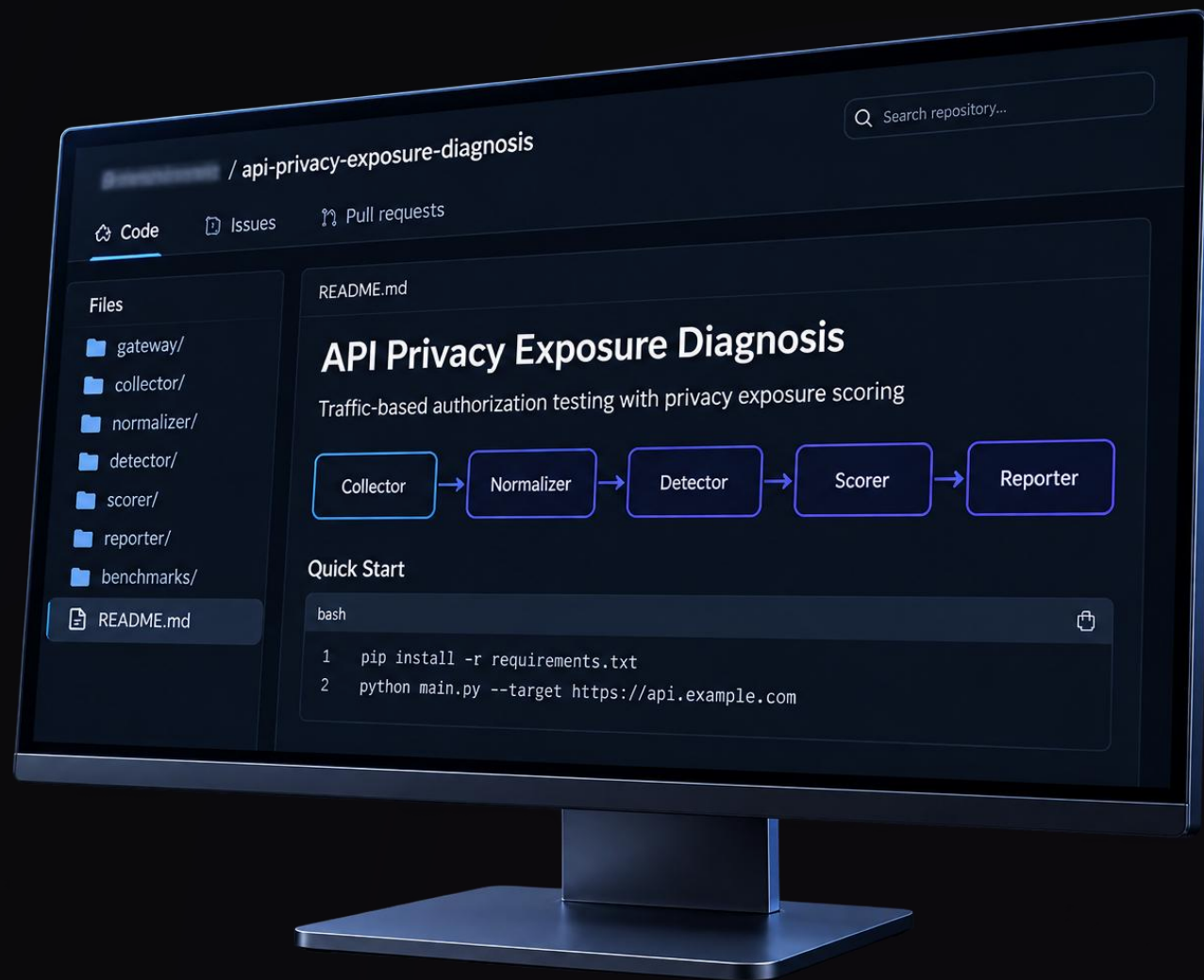
Fig. 2. Comparison of detected privacy exposure cases by category.

# 04

## 프로젝트 목표 산출물

Project Deliverables

### 3. 오픈소스 공개



# 질의응답

Q & A



# 들어주셔서 감사합니다.

Thank you for Listening

곽민경, 심재훈, 양유상, 임성빈

2026-2 정보보안S/W융합전공 Project Kick-Off